

Industrial Security (Bachelor)

Exercise Sheet – Section 07

Risk Management

Goal. Practise the risk-management toolkit from Section 07 on small but realistic OT scenarios. Each task is deliberately scoped so that a single student can answer it in 3–10 sentences (or one small diagram / table). Use real frameworks where named: IEC 61511, IEC 61882 (HAZOP), ISA TR84.00.09, NIST SP 800-30 R1, AIChE/CCPS LOPA, INL CCE (Bochman & Freeman), and FAIR (Jones & Freund). Cite figures honestly – “I estimated” is fine, “the vendor told me” must say so.

Exercise 7.1 – Build a 5×5 Risk Matrix (Water-Treatment Plant)

You are the security engineer at a small municipal water-treatment plant (50,000 residents served, one chlorine dosing skid, one SCADA HMI, two remote pumping stations on cellular routers).

1. Sketch a 5×5 risk matrix with axes *Likelihood* (Very Unlikely → Very Likely) and *Consequence* (Negligible → Catastrophic). Use a green / yellow / orange / red colour band of your choice and write down the policy rule (which cells are which colour).
2. Place the following five risks on the matrix and justify the colour assignment for each in 1–2 sentences: (a) ransomware on the historian VM, (b) spoofed Modbus write to the chlorine dosing setpoint, (c) stolen maintenance laptop with cached HMI password, (d) loss of cellular link to the south pumping station for 30 min, (e) vendor remote-support session left open over the weekend.

Reference: NIST SP 800-30 R1, App. I (likelihood / impact scales); IEC 62443-3-2 zones & conduits for the consequence side.

Exercise 7.2 – Bow-Tie: Unauthorised Setpoint Modification

Top event: “*unauthorised modification of the chlorine residual setpoint on the dosing PLC*” (the value that decides how much chlorine is injected).

1. List **three plausible causes** on the left side of the bow-tie (mix at least one cyber and one human-error cause).
2. List **three consequences** on the right side, covering *at least two* of the OT dimensions (safety, environment, production, reputation, regulatory).
3. Place **two preventive barriers** on the left and **two mitigating barriers** on the right. For each barrier, name whether it is procedural, technical, or physical.

A hand sketch (photo / scan) is acceptable; do not over-engineer the diagram.

Exercise 7.3 – Cyber-HAZOP on Pump P-101

Process node: pump P-101 feeds reactor R-201 with cooling water. Flow setpoint is written by the BPCS over Modbus/TCP; an alarm is configured at $\pm 20\%$ deviation; no SIS is installed on this loop. Walk the five core HAZOP guide words from a *cyber* perspective:

1. **No** flow – name one cyber-induced cause and the consequence.
2. **More** flow.
3. **Less** flow.
4. **Reverse** flow.
5. **As well as** (an unintended additional substance / signal).

For each, write one sentence on the cyber cause and one sentence on the consequence to R-201. Cite IEC 61882:2016 for the guide-word set and ISA TR84.00.09:2017 for the cyber adaptation.

Exercise 7.4 – LOPA Calculation

Hazard scenario: *runaway exotherm in reactor R-201 caused by loss of cooling-water flow*. Initiating-event frequency $f_i = 0.1/\text{year}$ (one failure of P-101 expected every ten years, taken from the maintenance log).

1. Decide which of the following layers you would credit as *independent protection layers (IPLs)* per CCPS LOPA, and assign a realistic PFD to each: BPCS flow-control loop, high-temperature alarm with operator response, SIS SIL-2 trip, mechanical pressure relief valve.
2. Compute the residual (mitigated) frequency $f_{\text{mit}} = f_i \cdot \prod \text{PFD}_k$.
3. State one assumption that, if wrong, invalidates the result (think *independence*).

PFD ranges to use: BPCS loop $\approx 10^{-1}$, alarm + operator $\approx 10^{-1}$, SIS SIL-2 $\approx 10^{-2}$ (SIL-3 $\approx 10^{-3}$), PSV $\approx 10^{-2}$ (CCPS, AIChE, 2001).

Exercise 7.5 – CCE Step 1: Consequence Prioritisation

You are the new plant manager of a mid-sized speciality-chemicals site (batch reactors, two storage tanks of a toxic intermediate, one rail-loading spur, ~ 400 staff). Following INL's Consequence-Driven Cyber-Informed Engineering (CCE) methodology, perform *Phase 1* only.

1. Name the **top three** “unacceptable” outcomes the business cannot survive (think existential, not annoying).
2. Rank them **1, 2, 3** and explain the ranking rationale in 2–3 sentences (criteria: loss of life, regulatory licence to operate, irreversible environmental damage, weeks of lost production, etc.).
3. Note which CCE *Phase* comes next and what it produces.

Reference: A. Bochman & S. Freeman, *Countering Cyber Sabotage*, INL/CRC Press, 2021.

Exercise 7.6 – Risk Response: When Each Choice Is Wrong

For each of the four ISO 31000:2018 risk responses, give:

- one concrete OT example where the response is the *right* choice, and
- one situation where the same response would be the *wrong* choice (and what should be done instead).

The four responses: **Transfer, Accept, Mitigate, Avoid**. Keep each bullet to 1–2 sentences; the trap is treating “Accept” as a default or “Transfer” as risk reduction.

Exercise 7.7 – Cyber Insurance and the War Exclusion

Read a short summary of *Merck & Co. v. Ace American Insurance Co.* (Superior Court of New Jersey, Appellate Division, 2022) – the case arose from the 2017 NotPetya wiper that caused USD 1.4 bn of damage at Merck.

1. In your own words (2–3 sentences) summarise why the insurer invoked the “hostile or warlike action” exclusion, and why the court held that the exclusion did *not* apply.
2. State two practical consequences for an OT operator buying cyber insurance in 2026 (think: policy wording, sub-limits, attribution clauses).
3. Why is “insurance” *not* a substitute for mitigation when the consequence dimension is safety?

Reference: Merck v. Ace American, A-1879-21, NJ App. Div., 2022.

Exercise 7.8 – Quantitative FAIR Estimate

Scenario: ransomware encrypts the plant historian (Wonderware / AVEVA), forcing the operations team to fall back to paper logs for several days while the VM is rebuilt from offline backup. No production stop, but regulatory reporting is delayed and a third-party forensic team is engaged. Compute a FAIR-style *loss exposure* (per Jones & Freund, 2014):

1. Estimate the **Threat Event Frequency (TEF)** per year (how often does a ransomware actor reach the historian VM?).
2. Estimate the **Vulnerability** (probability that the action succeeds given current controls – EDR, segmentation, backups).
3. Estimate **Loss Magnitude (LM)** in EUR – primary (response, recovery, lost productivity) plus secondary (regulatory, reputational).
4. Compute Loss Exposure = $TEF \times Vuln \times LM$ and show the arithmetic. State the single biggest source of uncertainty in your estimate.

Exercise 7.9 – Risk Register Row

Write **one complete row** of a risk register for a real risk in the university lab (or the sample plant used in your project group). Use the following columns and fill every cell:

- **ID** (e.g. R-0T-014)
- **Description** (1 sentence; threat → vulnerability → impact)
- **Likelihood** (qualitative, 5-point) and **Consequence** (qualitative, 5-point) with a one-line rationale
- **Owner** (named role, not “IT”)
- **Treatment** (avoid / mitigate / transfer / accept + control)
- **Residual rating** after treatment
- **Review date** (a real date in 2026 or 2027)

Format as a small table or a labelled list. Avoid pseudo-precision (no “risk score 7.42”); see Exercise 7.10.

Exercise 7.10 – Spot the False Precision

A vendor demo tool reports a “**risk score of 8.42 / 10**” for one of your PLCs and offers to “reduce it to 4.10” if you buy their hardening package.

1. Name three things that are methodologically wrong with a two-decimal score on a 10-point qualitative scale.
2. List four questions you would ask the vendor before quoting that number to your management (think: input data, weighting, independence of factors, calibration).
3. Suggest one defensible alternative the vendor could offer instead (hint: NIST SP 800-30 semi-quantitative bands, or a FAIR range with a stated confidence interval).